

AD01 – Manual de Operaciones de la Autoridad Certificadora (AC)

ID Documento: GOYA-AD01-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto PKI / Criptografico
Revision operativa	Administrador CA	Administrador de la Autoridad Certificadora
Revision legal	Asesor Legal	Asesor Legal del PSC
Aprobacion	Pendiente	Gerente General

1.2 Distribucion

Este documento se clasifica como **Confidencial** y se distribuye a las siguientes funciones:

Destinatario	Forma de entrega	Acuse requerido
Gerencia General	Copia controlada digital	Si
Oficial de Seguridad	Copia controlada digital	Si
Administrador CA	Copia controlada digital	Si

Destinatario	Forma de entrega	Acuse requerido
Administrador RA	Copia controlada digital	Si
Custodios de Fragmentos M-of-N	Extracto seccion 3.1	Si
Operador de Backup	Extracto secciones 3.8, 6	Si
Auditor Interno	Copia controlada digital	Si
Arquitecto PKI	Copia controlada digital	Si

Toda distribucion se registra en el libro de control de documentos del SGSI (PS04 seccion 4.2). Las copias impresas estan prohibidas salvo autorizacion explicita del Oficial de Seguridad.

1.3 Dependencias

Documento	ID	Relacion con este manual
Plan de Gestion de Riesgos y Amenazas	PS01	Riesgos AC-01 a AC-05 determinan los controles operativos descritos en secciones 3 y 6
Politica de Seguridad	PS02	Politica marco de seguridad aplicable a todo el personal y sistemas de la CA
Plan de Continuidad de Negocio	PS03	Procedimientos de contingencia referenciados en seccion 6; RPO/RTO de la CA
Plan del SGSI	PS04	Marco del sistema de gestion; inventario de activos criptograficos
Plan de Auto-evaluacion	PS05	Metricas de desempeno operacional de la CA; indicadores de cumplimiento
Plan de Administracion de Llaves	PS06	Ciclo de vida de claves CA; parametros criptograficos ML-DSA-65 y Ed25519
Plan de Gestion de Incidentes	PS07	Respuesta ante incidentes que afecten operacion o integridad de la CA
Modelo Operacional de la CA	PO03	Arquitectura de servicios; flujos de emision, revocacion y sellado de tiempo
Modelo Operacional de la RA	PO04	Interaccion AR-AC para solicitudes de certificados y revocaciones
Declaracion de Practicas de Certificacion	CPS	Practicas de emision, revocacion y renovacion publicadas a suscriptores

2. Dotacion de Personal

2.1 Roles y responsabilidades

Rol	Cantidad minima	Responsabilidades principales
Administrador CA	2	Operacion diaria de la CA intermedia; emision y revocacion de certificados; generacion de CRL; mantenimiento del servicio OCSP; actualizacion de software CA
Oficial de Seguridad	1	Definicion y supervision de politicas de seguridad; aprobacion de cambios en configuracion CA; revision de logs de auditoria; gestion de incidentes de seguridad
Custodio de Fragmento M-of-N	5 (minimo 3 activos)	Custodia de un fragmento Shamir de la clave raiz; participacion en ceremonias de clave; no poseen acceso operativo a la CA intermedia
Operador de Backup	1	Ejecucion de respaldos programados de HSM y RocksDB; verificacion de integridad de respaldos; ejecucion de restauraciones en simulacros
Auditor Interno	1	Revision periodica de registros de auditoria; verificacion de cumplimiento con CPS y este manual; preparacion de informes para auditoria externa

2.2 Matriz de separacion de funciones

La siguiente matriz define las incompatibilidades entre roles para cumplir con el principio de separacion de funciones (EA-103 seccion 4.21.2, DS 181 articulo 14).

Funcion	Admin CA	Oficial Seg.	Custodio M-of-N	Op. Backup	Auditor
Emitir certificados	X	-	-	-	-
Revocar certificados	X	A	-	-	-
Aprobar cambios de configuracion	-	X	-	-	-
Participar en ceremonia de clave	-	X	X	-	-
Ejecutar respaldos de HSM	-	-	-	X	-

Funcion	Admin CA	Oficial Seg.	Custodio M-of-N	Op. Backup	Auditor
Revisar logs de auditoria	-	X	-	-	X
Acceder a sala de ceremonia	-	X	X	-	-
Modificar politicas CPS/CP	-	X	-	-	-

Leyenda: X = responsable, A = aprobador, - = sin acceso.

Ninguna persona puede ejercer simultaneamente los roles de Administrador CA y Oficial de Seguridad. Los Custodios de Fragmento M-of-N no pueden desempenar funciones operativas sobre la CA intermedia.

2.3 Requisitos de capacitacion

Rol	Capacitacion requerida	Frecuencia
Administrador CA	Operacion de HSM FIPS 140-2; administracion PKI X.509; procedimientos de emision y revocacion; uso de <code>crates/pqc_crypto_module/</code>	Inicial + anual
Oficial de Seguridad	ISO 27001 Lead Implementer; gestion de incidentes; marco legal Ley 19.799 y DS 181; auditoria de seguridad	Inicial + anual
Custodio de Fragmento M-of-N	Protocolo de ceremonia de clave; custodia de fragmentos Shamir; procedimientos de emergencia	Inicial + ante cada ceremonia
Operador de Backup	Procedimientos de respaldo HSM y RocksDB; restauracion en entorno de prueba; verificacion de integridad	Inicial + semestral
Auditor Interno	ISO 19011 auditoria de sistemas; requisitos EA-103; marco normativo PSC chileno	Inicial + anual

Toda capacitacion se registra en el expediente del personal (PS04 seccion 7.3). El Oficial de Seguridad verifica la vigencia de las capacitaciones trimestralmente.

2.4 Continuidad del personal

En caso de ausencia prolongada o desvinculacion de personal critico, se aplica el procedimiento de continuidad definido en PS03 seccion 8.2. Los roles de Administrador CA y Oficial de Seguridad requieren un suplente designado y capacitado en todo momento.

3. Procedimientos Operacionales

3.1 Generacion de pares de llaves CA

3.1.1 Alcance

Este procedimiento cubre la generacion de pares de llaves para la CA raiz y la CA intermedia. La CA raiz utiliza HSM FIPS 140-2 Level 3 con algoritmo ML-DSA-65 (FIPS 204). La CA intermedia utiliza HSM FIPS 140-2 Level 2 con el mismo algoritmo. Ed25519 (FIPS 186-5) se mantiene como algoritmo de respaldo para interoperabilidad.

3.1.2 Requisitos previos

1. Sala de ceremonia air-gapped verificada: sin conectividad de red, sin dispositivos de comunicacion inalambrica, CCTV operativo con grabacion.
2. HSM inicializado y verificado (firmware autenticado, logs de integridad limpios).
3. Minimo 3 de 5 Custodios de Fragmento presentes (esquema Shamir 3-of-5).
4. Oficial de Seguridad presente como director de ceremonia.
5. Al menos 2 testigos independientes (uno externo a la organizacion cuando sea factible).
6. Acta de ceremonia pre-impresa con campos para registro de cada paso.
7. Medios de almacenamiento para fragmentos Shamir: tarjetas inteligentes o dispositivos USB cifrados, uno por custodio.

3.1.3 Procedimiento – CA raiz

Paso	Accion	Responsable	Verificacion
1	Verificar identidad de todos los participantes mediante documento oficial con fotografia	Oficial de Seguridad	Registro en acta
2	Verificar integridad del HSM: firmware hash, logs de tamper, serial number	Administrador CA	Hash registrado en acta
3	Iniciar generacion de par de claves ML-DSA-65 en HSM con parametros FIPS 204	Administrador CA	Confirmacion en pantalla HSM

Paso	Accion	Responsable	Verificacion
	(categoria de seguridad 2, longitud de clave publica 1952 bytes, longitud de firma 3309 bytes)		
4	Exportar clave publica del HSM al medio de transporte	Administrador CA	Hash SHA-256 de clave publica registrado
5	Generar fragmentos Shamir 3-of-5 del secreto de activacion del HSM	Oficial de Seguridad	Verificacion de reconstruccion con 3 fragmentos de prueba
6	Distribuir fragmentos a cada Custodio en sobre sellado y numerado	Oficial de Seguridad	Firma de recepcion por cada Custodio
7	Verificar reconstruccion: reunir 3 fragmentos cualesquiera y confirmar que activan el HSM	Administrador CA + Oficial de Seguridad	Exito de activacion registrado
8	Destruir los fragmentos de prueba utilizados en paso 7	Oficial de Seguridad	Destruccion presenciada por testigos
9	Generar certificado auto-firmado de CA raiz con perfil X.509v3 conforme RFC 5280	Administrador CA	Verificacion de extensiones: basicConstraints CA:TRUE, keyUsage keyCertSign + cRLSign
10	Exportar certificado raiz a medios de distribucion	Administrador CA	Hash SHA-256 registrado en acta
11	Apagar HSM y almacenar en	Oficial de Seguridad + Custodio designado	Registro de cierre en acta

Paso	Accion	Responsable	Verificacion
12	caja fuerte con doble cerradura Firmar acta de ceremonia por todos los participantes y testigos	Todos	Acta completa archivada

3.1.4 Procedimiento – CA intermedia

El procedimiento sigue los pasos 1 a 8 del procedimiento de CA raiz con las siguientes diferencias:

- HSM: FIPS 140-2 Level 2, conectado a la infraestructura operacional.
- En el paso 9, se genera un CSR (Certificate Signing Request) en lugar de un certificado auto-firmado.
- El CSR se transporta a la sala de ceremonia de la CA raiz en medio air-gapped para su firma.
- La CA raiz firma el certificado de la CA intermedia (requiere activacion del HSM raiz con 3-of-5 Custodios).
- El certificado firmado se transporta de vuelta e instala en el HSM de la CA intermedia.
- Se verifica la cadena de confianza: certificado intermedio validado contra certificado raiz.

3.1.5 Registro de auditoria

Cada ceremonia genera los siguientes registros, almacenados en el sistema de auditoria de la CA con integridad protegida por blockchain (consenso HotStuff BFT, 4 nodos):

- Acta fisica firmada (original en boveda, copia digital escaneada).
- Video de la ceremonia (retencion minima 5 anos).
- Hashes SHA-256 de claves publicas y certificados generados.
- Registro de asistencia con identificacion de cada participante.
- Log del HSM exportado y firmado digitalmente.

Referencia cruzada: PS06 seccion 4 (generacion de claves), PO03 seccion 4.1 (ceremonia).

3.2 Publicacion de CRL

3.2.1 Frecuencia de publicacion

Tipo de CRL	Frecuencia	nextUpdate	Tamano maximo estimado
CRL completa de CA intermedia	Cada 24 horas	48 horas desde thisUpdate	Sin limite

Tipo de CRL	Frecuencia	nextUpdate	Tamano maximo estimado
Delta CRL de CA intermedia	Cada 4 horas	8 horas desde thisUpdate	Sin limite
CRL de CA raiz	Cada 6 meses	12 meses desde thisUpdate	Minimo (solo CA intermedia)

La generacion automatica de CRL se ejecuta mediante tarea programada en la CA intermedia. En caso de revocacion de emergencia, se genera una CRL fuera de ciclo dentro de los 60 minutos siguientes a la revocacion.

3.2.2 Perfil de CRL (RFC 5280)

Campo	Valor
version	v2
signature	ML-DSA-65 (OID 2.16.840.1.101.3.4.3.18) o Ed25519 (OID 1.3.101.112) segun algoritmo CA
issuer	DN de la CA emisora
thisUpdate	Marca temporal UTC de generacion
nextUpdate	Segun tabla 3.2.1
revokedCertificates	Lista de seriales revocados con CRLReason (RFC 5280 seccion 5.3.1)
crlExtensions	AuthorityKeyIdentifier, CRLNumber (monotonicamente creciente), DeltaCRLIndicator (solo para Delta CRL), IssuingDistributionPoint

3.2.3 Puntos de distribucion

Canal	URL / Ruta	Protocolo
HTTP (principal)	GET /api/v1/crl	HTTPS con certificado TLS de la CA intermedia
HTTP (Delta CRL)	GET /api/v1/crl/delta	HTTPS
Repositorio de certificados	GET /api/v1/repository/crl	HTTPS

La CRL se firma con la clave privada de la CA emisora almacenada en HSM. El proceso de firma requiere activacion del HSM de la CA intermedia (operacion automatizada, sin intervencion de Custodios para la CA intermedia).

3.2.4 Procedimiento de publicacion

1. El servicio de generacion de CRL consulta la base de datos de certificados revocados en RocksDB.
2. Se construye la estructura CRL conforme al perfil definido en 3.2.2.

3. Se firma la CRL con la clave de la CA intermedia via HSM.
4. Se almacena la CRL firmada en RocksDB con clave `crl:{timestamp}:{sequence}`.
5. Se publica en los puntos de distribucion definidos en 3.2.3.
6. Se registra evento de publicacion en el log de auditoria con hash SHA-256 de la CRL.
7. Se verifica la accesibilidad de la CRL desde un nodo externo.

Referencia cruzada: PS06 seccion 5.4 (revocacion de claves), PO03 seccion 5.2 (servicio CRL).

3.3 Publicacion de informacion de certificados

3.3.1 Repositorio de certificados

Los certificados emitidos se publican en el repositorio HTTP del PSC, accesible mediante:

Endpoint	Descripcion	Formato
GET /api/v1/certificates/{serial}	Consulta de certificado individual por numero de serie	DER (application/pkix-cert) o PEM (application/pem-certificate-chain)
GET /api/v1/repository/certificates	Listado paginado de certificados vigentes	JSON con metadatos
GET /api/v1/certificates/chain	Cadena de certificados completa (raiz + intermedia)	PEM concatenado

3.3.2 Servicio OCSP (RFC 6960)

El respondedor OCSP proporciona estado de revocacion en tiempo real:

Parametro	Valor
Endpoint	GET /api/v1/ocsp (metodo GET con codificacion base64 del OCSPRequest en URL) y POST /api/v1/ocsp
Tiempo de respuesta	Maximo 3 segundos bajo carga normal
Firma de respuesta	Delegada a certificado OCSP Responder firmado por CA intermedia
Algoritmo de firma	ML-DSA-65 (primario), Ed25519 (respaldo)
Validez de respuesta	producedAt + 24 horas (nextUpdate)
Nonce	Soportado (RFC 8954)

El respondedor OSCP consulta el estado de revocacion directamente en RocksDB. No depende de la CRL para determinar el estado; ambos sistemas se alimentan de la misma fuente de datos de revocacion.

3.3.3 Transparencia de certificados

Los certificados FEA emitidos se registran en el log de transparencia interno del PSC, almacenado en la cadena de bloques con consenso HotStuff BFT. Cada entrada contiene:

- Hash SHA-256 del certificado DER.
- Marca temporal de emision (timestamp del bloque).
- Identificador del operador que aprobo la emision.
- Hash del bloque que contiene el registro.

3.4 Distribucion de llaves y certificados

3.4.1 Distribucion del certificado raiz

El certificado de la CA raiz se distribuye mediante los siguientes canales:

Canal	Procedimiento	Verificacion
Sitio web del PSC	Publicacion en pagina HTTPS dedicada con fingerprint SHA-256	Hash publicado en medio independiente (Diario Oficial o similar)
Endpoint API	GET /api/v1/certificates/chain retorna la cadena completa	Verificacion de firma de la cadena
Comunicacion directa	Entrega en medio fisico a AR y entidades de confianza	Acuse de recibo con verificacion de fingerprint

3.4.2 Entrega de certificados a suscriptores

Los certificados emitidos se entregan al suscriptor a traves de la AR conforme al procedimiento definido en PO04 seccion 6.3:

1. La AC genera el certificado firmado tras recibir aprobacion de la AR.
2. El certificado se almacena en el repositorio de la AC.
3. La AC notifica a la AR que el certificado esta disponible.
4. La AR descarga el certificado via GET /api/v1/certificates/{serial}.
5. La AR entrega el certificado al suscriptor junto con instrucciones de instalacion y verificacion de fingerprint.

3.4.3 Canal seguro AC-AR

Toda comunicacion entre AC y AR se realiza sobre TLS 1.3 mutuo (mTLS) con certificados emitidos por la CA intermedia. Los certificados de autentificacion de la AR se emiten con Extended Key Usage id-kp-clientAuth.

3.5 Renovacion de certificados

3.5.1 Plazos de renovacion

Tipo de certificado	Vigencia	Inicio de proceso de renovacion	Notificacion al suscriptor
CA raiz	20 anos	2 anos antes del vencimiento	N/A (proceso interno)
CA intermedia	10 anos	1 ano antes del vencimiento	Notificacion a AR
Suscriptor FEA	2 anos	90 dias antes del vencimiento	Correo electronico a los 90, 60 y 30 dias
Suscriptor FES	1 ano	60 dias antes del vencimiento	Correo electronico a los 60 y 30 dias
OCSF Responder	1 ano	60 dias antes del vencimiento	N/A (proceso interno)
TSA	2 anos	90 dias antes del vencimiento	N/A (proceso interno)

3.5.2 Modalidades de renovacion

Re-firma (re-sign): Se utiliza cuando la clave del suscriptor permanece valida y no existe sospecha de compromiso. Se emite un nuevo certificado con la misma clave publica, nuevo numero de serie y nuevas fechas de vigencia.

Re-clave (re-key): Se utiliza cuando la clave del suscriptor se acerca al final de su periodo criptografico recomendado, cuando existe sospecha de debilitamiento del algoritmo, o por solicitud del suscriptor. Se genera un nuevo par de claves y se emite un certificado con la nueva clave publica.

3.5.3 Procedimiento de renovacion

1. El sistema de monitoreo detecta certificados proximos a vencer (consulta diaria a RocksDB).
2. Se envia notificacion al suscriptor via AR segun los plazos de la tabla 3.5.1.
3. El suscriptor inicia la solicitud de renovacion a traves de la AR.
4. La AR verifica que la identidad del suscriptor permanece vigente (referencia PO04 seccion 5.2).
5. Para re-firma: la AR envia solicitud de re-emision a `POST /api/v1/certificates/renew` con el numero de serie del certificado actual.
6. Para re-clave: el suscriptor genera un nuevo par de claves, la AR envia un nuevo CSR a la AC.
7. La AC emite el nuevo certificado y lo publica en el repositorio.
8. La AR notifica al suscriptor la disponibilidad del nuevo certificado.
9. El certificado anterior permanece valido hasta su fecha de expiracion original, salvo revocacion explicita.

3.6 Renovacion post-revocacion

Cuando un certificado ha sido revocado, el suscriptor debe obtener un certificado nuevo mediante el siguiente procedimiento:

1. El suscriptor solicita un nuevo certificado a traves de la AR.
2. La AR ejecuta el proceso completo de verificacion de identidad (PO04 seccion 4), sin excepciones por historial previo del suscriptor.
3. El suscriptor genera un nuevo par de claves. No se permite reutilizar la clave del certificado revocado.
4. La AR envia el nuevo CSR a la AC via POST /api/v1/certificates/fea o el endpoint correspondiente segun tipo de certificado.
5. La AC valida que la clave publica del CSR no coincide con ninguna clave previamente revocada.
6. La AC emite el nuevo certificado con un nuevo numero de serie.
7. El certificado revocado permanece en la CRL hasta su fecha de expiracion original.

Referencia cruzada: PS06 seccion 5.5 (re-emision post-compromiso), PO04 seccion 7 (revocacion desde AR).

3.7 Controles de acceso a sistemas AC

3.7.1 Modelo de control de acceso

La CA implementa control de acceso basado en roles (RBAC) conforme a la matriz de separacion de funciones definida en seccion 2.2. El sistema de control de acceso (enforce_acl en src/api/) aplica las siguientes reglas:

Nivel	Mecanismo	Descripcion
Red	Segmentacion de red	CA raiz en red aislada (air-gap); CA intermedia en VLAN dedicada con firewall de capa 7
Sistema operativo	Autenticacion multifactor	Acceso a servidores CA requiere certificado de cliente + contrasena + OTP
Aplicacion	RBAC + ACL	Roles definidos en seccion 2.1; permisos asignados por rol; variable de entorno ACL_MODE controla el modo
HSM	PIN + M-of-N	Acceso al HSM raiz requiere 3-of-5 fragmentos Shamir; HSM intermedio requiere PIN de operador
Fisico	Control biometrico + tarjeta	Acceso a sala de servidores y sala de ceremonia

3.7.2 Gestion de acceso privilegiado

- Toda sesion privilegiada se registra con inicio, fin, comandos ejecutados e identidad del operador.

- Las credenciales de administrador se rotan cada 90 dias.
- El acceso remoto a la CA intermedia requiere VPN con certificado de cliente emitido por la propia CA y autenticacion multifactor.
- No se permite acceso remoto a la CA raiz bajo ninguna circunstancia.

3.7.3 Registro de auditoria de acceso

Todos los eventos de acceso se registran en el log de auditoria persistido en RocksDB (cuando STORAGE_BACKEND=rocksdb y RUST_BC_ENV=production). Los registros incluyen:

- Identidad del operador (DID formato did:goya:{pubkey_hex[. .16]}).
- Marca temporal UTC.
- Accion realizada.
- Resultado (exito o fallo con codigo de error).
- Direccion IP de origen.

El Oficial de Seguridad y el Auditor Interno revisan los logs de auditoria semanalmente. Las anomalias se escalan conforme a PS07.

3.8 Respaldo y recuperacion

3.8.1 Estrategia de respaldo

Componente	Metodo	Frecuencia	Retencion	Ubicacion
Clave privada CA raiz (HSM)	Backup cifrado de HSM a HSM	Tras cada ceremonia de clave	Permanente	Bodega secundaria en ubicacion geografica distinta
Clave privada CA intermedia (HSM)	Backup cifrado de HSM a HSM	Semanal	5 anos	Bodega secundaria
Fragmentos Shamir	Respaldo en tarjeta inteligente secundaria por custodio	Tras cada ceremonia	Permanente	Custodia personal del Custodio (ubicacion declarada)
Base de datos RocksDB	Snapshot completo + WAL incremental	Diario (completo) + continuo (WAL)	5 anos	Almacenamiento cifrado off-site
Configuracion de la CA	Export de configuracion firmado	Ante cada cambio	5 anos	Repositorio de configuracion versionado
Logs de auditoria	Replica en nodo BFT secundario	Continuo (consenso)	7 anos	4 nodos BFT distribuidos

3.8.2 Objetivos de recuperacion

Escenario	RPO	RTO	Procedimiento
Fallo de CA intermedia (hardware)	4 horas	8 horas	Restaurar HSM backup + RocksDB snapshot en hardware de reemplazo
Fallo de CA intermedia (software)	0 (WAL)	2 horas	Redespliegue de aplicacion + restauracion de WAL
Compromiso de CA intermedia	0	24 horas	Revocacion + ceremonia de nueva clave intermedia (seccion 6.2)
Compromiso de CA raiz	0	72 horas	Procedimiento de emergencia seccion 6.1
Desastre en sitio principal	24 horas	48 horas	Activacion de sitio de contingencia (PS03 seccion 9)

Referencia cruzada: PS03 secciones 8-9 (BCP/DRP), PS06 seccion 6 (respaldo de claves).

3.8.3 Procedimiento de restauracion

1. El Oficial de Seguridad autoriza la restauracion y designa al equipo de recuperacion.
2. Se verifica la integridad del backup mas reciente (hash SHA-256 comparado con registro de auditoria).
3. Para restauracion de HSM: se requiere presencia de 3-of-5 Custodios para activacion del HSM de respaldo.
4. Se restaura la base de datos RocksDB desde el snapshot mas reciente y se aplican los WAL incrementales.
5. Se verifica la cadena de certificados: certificado raiz, certificado intermedio, certificado OCSP, certificado TSA.
6. Se ejecutan pruebas de emision y revocacion en modo de prueba antes de restaurar el servicio.
7. Se publica una CRL actualizada inmediatamente despues de la restauracion.
8. Se notifica a la AR y a los suscriptores afectados si hubo interrupcion del servicio.
9. Se documenta el incidente conforme a PS07 y se genera informe post-incidente.

4. Procedimientos de Actualizacion CPS/CP

4.1 Ciclo de revision

La Declaracion de Practicas de Certificacion (CPS) y la Politica de Certificados (CP) se revisan con la siguiente periodicidad:

Tipo de revision	Frecuencia	Responsable	Aprobador
Revision ordinaria	Semestral	Oficial de Seguridad	Gerencia General

Tipo de revision	Frecuencia	Responsable	Aprobador
Revision extraordinaria	Ante cambio normativo, incidente de seguridad o cambio tecnologico significativo	Oficial de Seguridad	Gerencia General
Revision pre-auditoria	30 dias antes de auditoria externa programada	Auditor Interno	Oficial de Seguridad

4.2 Procedimiento de cambio

1. El Oficial de Seguridad identifica la necesidad de cambio y documenta la justificacion.
2. Se redacta la propuesta de modificacion con las secciones afectadas y el texto propuesto.
3. El Arquitecto PKI revisa la viabilidad tecnica de los cambios.
4. El Asesor Legal verifica la conformidad con Ley 19.799, DS 181 y normativa vigente.
5. Gerencia General aprueba o rechaza la modificacion.
6. Se actualiza el documento con nuevo numero de version y fecha.
7. Se notifica a los suscriptores y partes de confianza conforme a seccion 4.3.
8. Se publica la version actualizada en el repositorio del PSC.
9. Se actualiza este manual (AD01) si los cambios afectan procedimientos operacionales.

4.3 Notificacion a suscriptores

Los cambios en CPS/CP se notifican a los suscriptores mediante:

- Publicacion en el sitio web del PSC con 30 dias de anticipacion para cambios sustantivos.
- Correo electronico a suscriptores con certificados vigentes.
- Registro del cambio en el log de transparencia de la CA.
- Para cambios que afecten derechos u obligaciones de los suscriptores: notificacion individual con acuse de recibo.

5. Interaccion AC-AR

5.1 Flujo de solicitud de certificado

Paso	Actor	Accion	Sistema / Endpoint
1	Suscriptor	Presenta solicitud de certificado y	Portal AR

Paso	Actor	Accion	Sistema / Endpoint
		documentacion de identidad a la AR	
2	AR	Verifica identidad del solicitante conforme a PO04 seccion 4	Sistema de verificacion AR
3	AR	Genera o recibe CSR del suscriptor	Sistema AR
4	AR	Envia CSR con confirmacion de verificacion de identidad a la AC	POST /api/v1/certificates/fea
5	AC	Valida CSR: formato, algoritmo, unicidad de clave publica	Modulo de validacion CA
6	AC	Emite certificado firmado con clave de CA intermedia	HSM + crates/ pqc_crypto_module/
7	AC	Publica certificado en repositorio y log de transparencia	RocksDB + blockchain BFT
8	AC	Notifica a AR la disponibilidad del certificado	Callback o polling
9	AR	Descarga certificado	GET /api/v1/certificates/{serial}
10	AR	Entrega certificado al suscriptor con instrucciones	Portal AR

5.2 Flujo de revocacion

Paso	Actor	Accion	Sistema / Endpoint
1			Portal AR

Paso	Actor	Accion	Sistema / Endpoint
	Suscriptor o AR	Solicita revocacion indicando motivo (CRLReason)	
2	AR	Verifica identidad del solicitante y autoridad para revocar	Sistema AR
3	AR	Envia solicitud de revocacion a la AC	POST /api/v1/certificates/{serial}/revoke
4	AC	Registra revocacion en base de datos con marca temporal y motivo	RocksDB
5	AC	Genera CRL fuera de ciclo si la revocacion es por compromiso de clave	Seccion 3.2
6	AC	Actualiza estado en respondedor OCSP	Inmediato
7	AC	Confirma revocacion a AR	Respuesta API

5.3 Acuerdo de nivel de servicio AC-AR

Metrica	Valor objetivo	Medicion
Disponibilidad del servicio de emision	99.5% mensual	Monitoreo de uptime del endpoint POST /api/v1/certificates/fea
Tiempo de emision de certificado	Maximo 5 minutos desde recepcion de CSR valido	Timestamp de solicitud vs timestamp de emision
Tiempo de revocacion	Maximo 30 minutos desde recepcion de solicitud valida	Timestamp de solicitud vs

Metrica	Valor objetivo	Medicion
Disponibilidad de CRL	99.9% mensual	timestamp de registro en CRL/OCSP Monitoreo de GET / api/v1/crl
Disponibilidad de OCSP	99.9% mensual	Monitoreo de GET / api/v1/ocsp
Tiempo de respuesta OCSP	Maximo 3 segundos	Medicion en el percentil 95

Las metricas se reportan mensualmente al Oficial de Seguridad y trimestralmente a Gerencia General. Los incumplimientos se escalan conforme a PS07.

6. Contingencias

6.1 Compromiso de CA raiz

En caso de sospecha o confirmacion de compromiso de la clave privada de la CA raiz:

1. El Oficial de Seguridad declara estado de emergencia y notifica a Gerencia General.
2. Se revoca el certificado de la CA intermedia inmediatamente.
3. Se publica CRL de la CA raiz fuera de ciclo.
4. Se notifica a todas las AR y suscriptores del compromiso.
5. Se notifica a la Subsecretaria de Economia (autoridad acreditadora) conforme a DS 181 articulo 17.
6. Se ejecuta ceremonia de generacion de nueva clave raiz (seccion 3.1.3) en un nuevo HSM.
7. Se emite nuevo certificado de CA intermedia firmado por la nueva CA raiz.
8. Se re-emiten los certificados de suscriptores vigentes con la nueva cadena de confianza.
9. Se publica el nuevo certificado raiz por los canales definidos en seccion 3.4.1.
10. Se genera informe post-incidente conforme a PS07 y se archiva como leccion aprendida en PS01.

El RTO para este escenario es de 72 horas (seccion 3.8.2).

6.2 Compromiso de CA intermedia

1. El Administrador CA notifica al Oficial de Seguridad.
2. Se detiene la emision de certificados inmediatamente.
3. Se revoca el certificado de la CA intermedia comprometida.
4. Se publica CRL de la CA raiz incluyendo el certificado intermedio revocado.
5. Se actualiza el respondedor OCSP.
6. Se ejecuta ceremonia de generacion de nueva clave intermedia (seccion 3.1.4).
7. Se re-emiten los certificados de suscriptores que estaban vigentes bajo la CA intermedia comprometida.

8. Se genera informe post-incidente conforme a PS07.

El RTO para este escenario es de 24 horas (sección 3.8.2).

6.3 Rollover planificado de claves

El rollover planificado de claves de la CA intermedia se ejecuta antes del vencimiento del certificado:

1. Se genera nuevo par de claves en HSM (sección 3.1.4) con anticipación definida en tabla 3.5.1.
2. Se emite nuevo certificado intermedio firmado por la CA raíz.
3. Se configura la CA para emitir nuevos certificados con la nueva clave.
4. Los certificados existentes permanecen válidos hasta su expiración.
5. Se publica la nueva cadena de certificados en GET /api/v1/certificates/chain.
6. Se notifica a las AR del cambio de clave.

6.4 Recuperación ante desastre

En caso de pérdida total del sitio principal:

1. Se activa el plan de continuidad de negocio (PS03 sección 9).
2. Se despliega la infraestructura de contingencia en sitio alternativo.
3. Se restauran los HSM de respaldo (sección 3.8.3).
4. Se restaura la base de datos RocksDB desde el último snapshot off-site.
5. Se verifican los 4 nodos de consenso BFT y se restablece el quorum.
6. Se ejecutan pruebas de servicio antes de restaurar operación pública.
7. Se publica CRL actualizada y se verifica el servicio OCSP.
8. Se notifica a las AR y suscriptores la restauración del servicio.

7. Referencias

7.1 Documentos internos del PSC

ID	Título
PS01	Plan de Gestión de Riesgos y Amenazas
PS02	Política de Seguridad
PS03	Plan de Continuidad de Negocio y Recuperación ante Desastres
PS04	Plan del Sistema de Gestión de Seguridad de la Información (SGSI)
PS05	Plan de Auto-evaluación
PS06	Plan de Administración de Llaves Criptográficas
PS07	Plan de Gestión de Incidentes
PO03	Modelo Operacional de la Autoridad Certificadora (AC)

ID	Título
PO04	Modelo Operacional de la Autoridad de Registro (AR)
CPS	Declaracion de Practicas de Certificacion
CP	Politica de Certificados

7.2 Normativa chilena

Norma	Título
Ley 19.799	Sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Norma tecnica para PSC acreditados
EA-103 v2.1	Guia de Acreditacion de Prestadores de Servicios de Certificacion

7.3 Estándares internacionales

Estandar	Título
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	X.509 Internet PKI Online Certificate Status Protocol - OCSP
RFC 3161	Internet X.509 PKI Time-Stamp Protocol (TSP)
RFC 8954	Online Certificate Status Protocol (OCSP) Nonce Extension
FIPS 140-2	Security Requirements for Cryptographic Modules
FIPS 204	Module-Lattice-Based Digital Signature Standard (ML-DSA)
FIPS 186-5	Digital Signature Standard (DSS) – Ed25519
eIDAS	Regulation (EU) No 910/2014 on Electronic Identification and Trust Services
ETSI TS 102 042	Policy Requirements for Certification Authorities Issuing Public Key Certificates
ISO/IEC 27001	Information Security Management Systems

Fin del documento AD01 – Manual de Operaciones de la Autoridad Certificadora (AC)